

SEGURIDAD DE LA INFORMACIÓN

y su Marco Legal

Aspectos Legales y Éticos de la Ingeniería en Software



Confidencialidad

Integridad

Disponibilidad

Marco Legal

Mg. Ana Yajaira Pallares Echavez



Ser » Hacer » Trascender

CONTENIDO SEGURIDAD DE LA INFORMACIÓN

01

¿Qué es la Seguridad de la Información?

Definición, pilares y conceptos clave

02

Amenazas y Vulnerabilidades

Tipos de ataques, ejemplos reales

03

Normativas y Estándares Internacionales

ISO 27001, NIST, RGPD

04

Marco Legal en Colombia y Latinoamérica

Ley 1273, Habeas Data, Ley 1581

05

Responsabilidad del Ingeniero de Software

Ética profesional y obligaciones legales

06

Casos Prácticos y Sanciones

Ejemplos reales de violaciones y consecuencias

¿QUÉ ES LA SEGURIDAD DE LA INFORMACIÓN?

"Conjunto de medidas preventivas y reactivas que permiten resguardar y proteger la información buscando mantener la confidencialidad, disponibilidad e integridad de los datos." — ISO/IEC 27001



CONFIDENCIALIDAD

Solo personas autorizadas acceden a la información.

Ejemplo: Cifrado de correos médicos de pacientes.



INTEGRIDAD

La información no es alterada sin autorización.

Ejemplo: Hash SHA-256 para verificar archivos descargados.



DISPONIBILIDAD

Acceso garantizado cuando sea necesario.

Ejemplo: Servidores redundantes en bancos online.



AMENAZAS Y VULNERABILIDADES COMUNES



Malware

WannaCry (2017): cifró 230,000 equipos en 150 países, causando daños por \$4,000M USD.



Phishing

Empleado del Banco de Bangladesh transfirió \$81M por correo falso del SWIFT.



Fuerza Bruta

Ataque a LinkedIn (2012): 117M contraseñas robadas por hashes MD5 sin sal.



Inyección SQL

Heartland Payment (2009): 130M tarjetas comprometidas mediante SQL Injection.



Ingeniería Social

Hacker Kevin Mitnick obtuvo acceso a sistemas críticos sin explotar código.



Ransomware

Colonial Pipeline (2021): pagó \$4.4M tras ataque que paralizó el suministro de combustible.



NORMATIVAS Y ESTÁNDARES INTERNACIONALES



ISO/IEC 27001

Sistema de Gestión de Seguridad de la Información (SGSI). Establece requisitos para proteger activos de información. Requiere análisis de riesgos, controles y mejora continua.

- Organizaciones de cualquier sector que manejen datos sensibles.

NIST CSF

Marco del Instituto Nacional de Estándares y Tecnología (EE.UU.). Cinco funciones: Identificar, Proteger, Detectar, Responder, Recuperar.

- Infraestructuras críticas, gobierno y empresas tecnológicas.

RGPD / GDPR

Reglamento General de Protección de Datos de la UE (2018). Multas de hasta 20M € o el 4% del volumen anual global de negocios.

- Toda empresa que trate datos de ciudadanos europeos.

PCI-DSS

Estándar de Seguridad para la Industria de Tarjetas de Pago. Exige cifrado, autenticación y monitoreo para transacciones con tarjeta.

- Comercios, bancos y procesadores de pagos.





LEY 1273 DE 2009 — Delitos Informáticos

- Art. 269A: Acceso abusivo a sistema informático → hasta 8 años de prisión
- Art. 269C: Interceptación de datos informáticos → hasta 3 años
- Art. 269F: Violación de datos personales → hasta 7 años + multa
- Art. 269J: Fraude informático → hasta 8 años de prisión

Ley 1581/2012

Protección de Datos Personales

Regula el tratamiento de datos. Exige consentimiento y define datos sensibles.

Ley 1266/2008

Habeas Data Financiero

Regula información en centrales de riesgo (DataCrédito, Cifin).

Dec. 1377/2013

Reglamentación Ley 1581

Autorización del titular para uso de datos, aviso de privacidad.



RESPONSABILIDAD DEL INGENIERO DE SOFTWARE

Obligaciones Técnicas

- Implementar cifrado para datos en tránsito y en reposo
- Aplicar principio de mínimo privilegio en accesos
- Realizar pruebas de penetración (pentest) periódicas
- Gestionar parches y actualizaciones de seguridad
- Documentar políticas de seguridad del sistema
- Usar autenticación multifactor (MFA) en sistemas críticos

Obligaciones Legales y Éticas

- Obtener consentimiento antes de recolectar datos personales
- Notificar brechas de seguridad a la autoridad competente
- Cumplir contratos de confidencialidad (NDA) con clientes
- No guardar más datos de los necesarios (minimización)
- Respetar licencias de software y derechos de autor
- Negarse a desarrollar software malicioso o espionaje ilegal



CASOS PRÁCTICOS Y SANCIONES

Facebook / Meta (2018 · EE.UU. / UE)

Cambridge Analytica: datos de 87 millones de usuarios utilizados sin consentimiento para manipulación política.

⚖️ **Multa FTC: \$5,000 millones USD. GDPR: €1.2M (Irlanda).**

Uber (2016 · EE.UU.)

Brecha que expuso 57M registros de usuarios y conductores. La empresa pagó \$100K a los hackers para ocultar el incidente.

⚖️ **Multa de \$148M USD por no notificar la brecha a tiempo.**

Equifax (2017 · EE.UU.)

SQL Injection expuso 147M registros (SSN, fechas de nacimiento, direcciones). Parche disponible 2 meses antes del ataque.

⚖️ **\$575M–\$700M USD al FTC. Responsabilidad del equipo de TI.**

Caso Colombia (2020 · Colombia)

Ingeniero accedió a sistemas del empleador anterior usando credenciales que nunca fueron revocadas tras su renuncia.

⚖️ **Condenado por Art. 269A Ley 1273 — 4 años de prisión.**

BUENAS PRÁCTICAS PARA EL DESARROLLADOR

1 Secure by Design

Incorpora la seguridad desde la fase de diseño, no como parche posterior. Usa modelado de amenazas (STRIDE, PASTA).

2 OWASP Top 10

Conoce las 10 vulnerabilidades web más críticas: Inyección, XSS, IDOR, etc. Usa OWASP ZAP para pruebas.

3 DevSecOps

Integra análisis de seguridad estático (SAST) y dinámico (DAST) en tu pipeline CI/CD con herramientas como SonarQube.

4 Control de Acceso

Aplica RBAC (Control por Roles) y el principio de menor privilegio. Revoca accesos al término de contratos.

5 Cifrado

Usa TLS 1.3 para tráfico, AES-256 para datos en reposo y bcrypt/Argon2 para contraseñas. Nunca MD5/SHA1.

6 Logs y Auditoría

Registra eventos de acceso, errores y cambios. Usa SIEM (ej. Splunk, ELK) para detección de anomalías.

CONCLUSIONES

01 La seguridad de la información es una responsabilidad compartida entre ingenieros, empresas y el Estado.

02 En Colombia, la Ley 1273/2009 criminaliza delitos informáticos con penas de hasta 8 años.

03 La tríada CIA (Confidencialidad, Integridad, Disponibilidad) es el fundamento técnico de toda política de seguridad.

04 Estándares como ISO 27001 y marcos como NIST no son opcionales para quienes manejan datos sensibles.

05 Un ingeniero de software negligente puede ser coimputado legalmente por brechas prevenibles.